Relatório Técnico Integrado

Autor: Deyvid Martins Mourao | Disciplina: Redes de computadores | Data: 10/11/2026

1 Topologia de rede

O ambiente foi implementado em Debian 13 (Trixie). Cada zona é um *network namespace* Linux, ligado por um par veth ao namespace `fw`, que roteia (`net.ipv4.ip_forward=1`) e filtra o tráfego com nftables. Os nomes de host são rótulos do projeto, pois os namespaces compartilham o hostname da máquina. Os hosts pc-usuario e pc-admin correspondem a dois endereços (10.0.2.20 e 10.0.2.5) da interface do namespace `lan`.

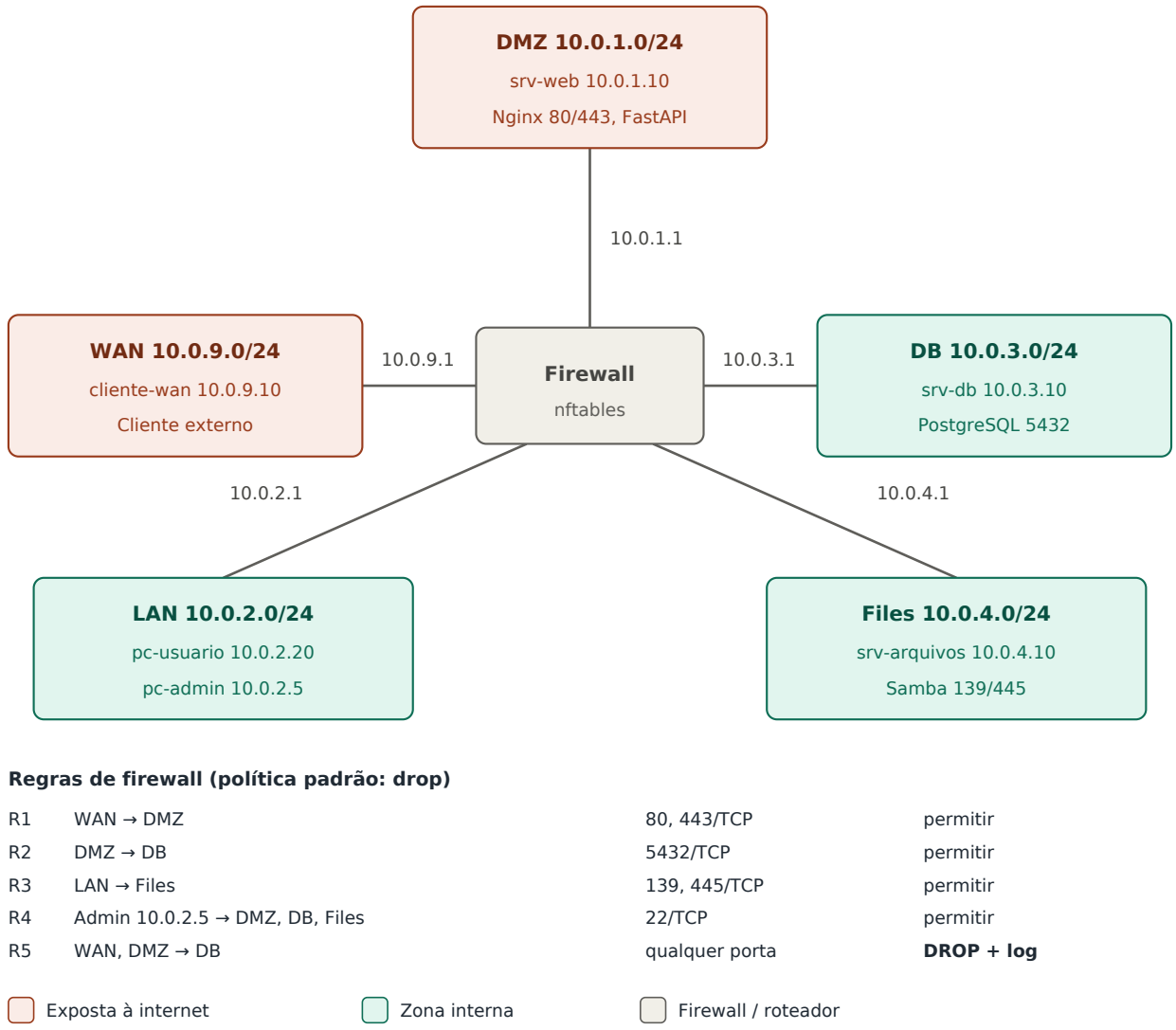


Figura 1. Topologia de rede com sub-redes, hosts, gateways e regras de firewall.

Tabela 1. Zonas, hosts e endereçamento

Zona	Sub-rede	Host	IP	Gateway (fw)	Serviços
WAN	10.0.9.0/24	cliente-wan	10.0.9.10	10.0.9.1	Cliente externo
DMZ	10.0.1.0/24	srv-web	10.0.1.10	10.0.1.1	Nginx 80/443, FastAPI em 127.0.0.1:8000, SSH
LAN	10.0.2.0/24	pc-usuario	10.0.2.20	10.0.2.1	Cliente
LAN	10.0.2.0/24	pc-admin	10.0.2.5	10.0.2.1	Administração via SSH
DB Zone	10.0.3.0/24	srv-db	10.0.3.10	10.0.3.1	PostgreSQL 17 (5432), SSH
Files	10.0.4.0/24	srv-arquivos	10.0.4.10	10.0.4.1	Samba (139/445), SSH

As interfaces do fw são `fw-wan`, `fw-dmz`, `fw-lan`, `fw-db` e `fw-files`, cada uma com o endereço .1 da sua rede. O endereçamento das zonas é estático e criado pelo script `scripts/topologia.sh`; o da DMZ também está

documentado em Netplan (interface dummy `dmz0`, 10.0.1.10/24) em `configs/netplan/99-dmz.yaml`.

2 Tabelas técnicas

2.1 Roteamento

O fw possui apenas rotas diretamente conectadas, uma para cada rede /24, com encaminhamento IPv4 ativo. Cada host tem rota padrão pelo endereço .1 da sua zona. Não há NAT nem saída das zonas para a WAN.

Tabela 2. Rotas por dispositivo

Dispositivo	Destino	Próximo salto	Interface
fw	10.0.9.0/24	diretamente conectada	fw-wan
fw	10.0.1.0/24	diretamente conectada	fw-dmz
fw	10.0.2.0/24	diretamente conectada	fw-lan
fw	10.0.3.0/24	diretamente conectada	fw-db
fw	10.0.4.0/24	diretamente conectada	fw-files
cliente-wan	10.0.9.0/24	diretamente conectada	eth0
cliente-wan	0.0.0.0/0 (padrão)	10.0.9.1	eth0
srv-web	10.0.1.0/24	diretamente conectada	eth0
srv-web	0.0.0.0/0 (padrão)	10.0.1.1	eth0
pc-usuario e pc-admin (namespace lan)	10.0.2.0/24	diretamente conectada	eth0
pc-usuario e pc-admin (namespace lan)	0.0.0.0/0 (padrão)	10.0.2.1	eth0
srv-db	10.0.3.0/24	diretamente conectada	eth0
srv-db	0.0.0.0/0 (padrão)	10.0.3.1	eth0
srv-arquivos	10.0.4.0/24	diretamente conectada	eth0
srv-arquivos	0.0.0.0/0 (padrão)	10.0.4.1	eth0

2.2 Mapeamento de portas

Tabela 3. Serviços, portas e controles de acesso

Serviço	Host	Porta	Escuta em	Controle de acesso
Nginx (HTTP)	srv-web	80/TCP	10.0.1.10	Redireciona com 301 para HTTPS
Nginx (HTTPS)	srv-web	443/TCP	10.0.1.10	TLS 1.2 e 1.3, HSTS, limite de 5 requisições por segundo por IP (burst 10), proxy reverso para o FastAPI
FastAPI (uvicorn)	srv-web	8000/TCP	127.0.0.1	Não exposto; acessível apenas pelo Nginx, no mesmo namespace
PostgreSQL 17	srv-db	5432/TCP	10.0.3.10	pg_hba.conf aceita somente 10.0.1.10/32, com scram-sha-256
Samba	srv-arquivos	139, 445/TCP	10.0.4.10	interfaces e bind interfaces only; compartilhamento [corporativo] com valid users
SSH	srv-web, srv-db, srv-arquivos	22/TCP	todas as interfaces do namespace	Somente chave ed25519; PasswordAuthentication no; PermitRootLogin no; AllowUsers admin

2.3 Regras de firewall e resultado dos testes

As regras estão na chain `forward` da tabela `inet projeto`, com política padrão **drop**. A ordem é relevante: a R2 (permitir DMZ → DB na porta 5432) precede a R5 (bloquear DMZ e WAN → DB em qualquer porta); se a ordem fosse inversa, a aplicação perderia o acesso ao banco. Antes das regras, `ct state invalid` é descartado e `ct state established,related` é aceito, o que torna o firewall stateful. Ao final, o tráfego não previsto é registrado com limite de 5/s (prefixo `DROP-OTHER:`) e descartado.

Interpretações adotadas para a matriz: “LAN (Admin)” é o endereço 10.0.2.5; “Todas as Zonas” são DMZ, DB e Files; “LAN (Usuários)” é a LAN inteira, restrita às portas 139 e 445.

Tabela 4. Regras de firewall e testes executados

Regra	Origem	Destino	Porta	Ação	Teste executado	Resultado
0	qualquer	qualquer	n/a	Stateful	established,related aceito; invalid descartado	Retornos entregues
R1	WAN	DMZ 10.0.1.10	80, 443/TCP	PERMITIR	:80 e :443 (esperado open); :8080 e :22 (esperado filtered)	4 PASS
R2	DMZ 10.0.1.10	DB 10.0.3.10	5432/TCP	PERMITIR	DMZ → DB:5432 (open); DMZ → DB:22 e DMZ → Files:445 (filtered)	3 PASS
R3	LAN	Files 10.0.4.10	139, 445/TCP	PERMITIR	Usuário → Files:445 e :139 (open); usuário → Files:22 e usuário → DB:5432 (filtered)	4 PASS
R4	LAN admin 10.0.2.5	DMZ, DB, Files	22/TCP	PERMITIR	Admin → DMZ, DB, Files:22 (open); usuário → DMZ:22 e DB:22 (filtered)	5 PASS
R5	WAN, DMZ	DB 10.0.3.10	qualquer	DROP + log	WAN → DB:5432 e :22 (filtered)	2 PASS

O script `scripts/testes.sh` executou 20 testes, com resultado **20 PASS e 0 FAIL**, incluindo ao menos um teste positivo e um negativo por regra, além de dois testes de SSH (a autenticação por chave funciona e a tentativa sem chave é recusada com `Permission denied (publickey)`). Os bloqueios resultaram em *timeout* (estado `filtered`), o que comprova DROP e não REJECT. Antes da aplicação do firewall (*baseline* sem regras), todos os serviços respondiam.

Contadores do nftables após os testes: R1 = 2, R2 = 1, R3 = 2, R4 = 5 e R5 = 9 pacotes; descarte final = 21 pacotes. O log do kernel registra `DROP-DB: IN=fw-wan OUT=fw-db ... DST=10.0.3.10` para as portas 5432 e 22, o que documenta a prevenção de acesso direto ao banco (`evidencias/log-drop-db.txt`).

3 Procedimentos operacionais padrão

3.1 Backup e restabelecimento do banco de dados

Objetivo. Gerar uma cópia diária do banco `banco`, guardá-la no servidor de arquivos e restabelecê-lo a partir dela. O fluxo respeita a matriz de firewall sem regra adicional: o administrador acessa o srv-db por SSH (R4) e grava o arquivo no srv-arquivos por Samba (R3). Ele substitui o script anterior (banco `recadastro`, envio direto do DB ao Samba), bloqueado pela matriz, que não permite DB → Files.

Pré-requisitos.

- Executar no pc-admin, com origem 10.0.2.5, único endereço liberado pela R4; por isso o SSH usa `-b 10.0.2.5`.
- Chave SSH do admin autorizada no srv-db e no srv-arquivos.
- No srv-db, delegação em `/etc/sudoers.d/` limitada aos comandos necessários: `admin ALL=(postgres) NOPASSWD: /usr/bin/pg_dump, /usr/bin/psql, /usr/bin/createdb, /usr/bin/dropdb`
- No srv-arquivos, diretório de destino: `sudo install -d -o usuario -g admin -m 2775 /srv/arquivos/backups`
- Credencial do Samba em `~/.smbcred` (modo 600, linhas `username=` e `password=`), mantida fora do repositório.

Procedimento de backup.

```
# 1. Nome do arquivo e atalho do SSH (origem 10.0.2.5, exigida pela R4)
DATA=$(date +%Y%m%d_%H%M%S); ARQ=banco_$DATA
SSH="ssh -b 10.0.2.5 -o BatchMode=yes"

# 2. Gerar o dump no srv-db
$SSH admin@10.0.3.10 "sudo -n -u postgres pg_dump -d banco" > /tmp/$ARQ.sql

# 3. Compactar e remover o .sql solto
tar -czf /tmp/$ARQ.tar.gz -C /tmp $ARQ.sql && rm /tmp/$ARQ.sql

# 4. Enviar ao servidor de arquivos (R3)
smbclient //10.0.4.10/corporativo -A ~/.smbcred -c "cd backups; put /tmp/$ARQ.tar.gz $ARQ.tar.gz"

# 5. Rotação: remover backups com mais de 7 dias e o arquivo temporário
$SSH admin@10.0.4.10 "find /srv/arquivos/backups -name 'banco_*.tar.gz' -mtime +7 -delete"
rm /tmp/$ARQ.tar.gz

# 6. Registrar a operação
echo "$(date '+%F %T') backup $ARQ.tar.gz enviado" >> ~/backup.log
```

Agendamento. Para execução diária, reunir os passos em um script no pc-admin e agendá-lo no cron do usuário admin:

```
0 2 * * * /home/admin/backup.sh >> /home/admin/backup.log 2>&1
```

Verificação. O arquivo mais recente deve aparecer na listagem, com tamanho maior que zero, e o log deve registrar a operação:

```
smbclient //10.0.4.10/corporativo -A ~/.smbcred -c "cd backups; ls"
tail -n 3 ~/backup.log
```

Reversão. Se o envio falhar, o arquivo permanece em `/tmp` e o passo 4 pode ser repetido. Para remover um backup enviado por engano: `smbclient //10.0.4.10/corporativo -A ~/.smbcred -c "cd backups; del ARQUIVO.tar.gz"`.

Restabelecimento a partir de um backup. Nunca restaurar sobre o banco em uso sem antes copiar o estado atual. O procedimento usa um banco temporário e só o promove depois de verificado.

```
# 1. Escolher e baixar o backup, depois descompactar
smbclient //10.0.4.10/corporativo -A ~/.smbcred -c "cd backups; ls"
smbclient //10.0.4.10/corporativo -A ~/.smbcred -c "cd backups; get banco_AAAAMMDD_HHMMSS.tar.gz"
tar -xzf banco_AAAAMMDD_HHMMSS.tar.gz

# 2. Copiar o estado atual (ponto de retorno)
SSH="ssh -b 10.0.2.5 -o BatchMode=yes"
$SSH admin@10.0.3.10 "sudo -n -u postgres pg_dump -d banco" > pre_restauracao.sql

# 3. Criar o banco temporário e restaurar nele
$SSH admin@10.0.3.10 "sudo -n -u postgres createdb -O usuario banco_tmp"
$SSH admin@10.0.3.10 "sudo -n -u postgres psql -d banco_tmp" < banco_AAAAMMDD_HHMMSS.sql

# 4. Verificar tabelas e contagens
$SSH admin@10.0.3.10 "sudo -n -u postgres psql -d banco_tmp -c '\dt'"
$SSH admin@10.0.3.10 "sudo -n -u postgres psql -d banco_tmp -c 'SELECT count(*) FROM <tabela>;'"

# 5. Com a aplicação parada, promover o banco restaurado
$SSH admin@10.0.3.10 "sudo -n -u postgres psql -c 'ALTER DATABASE banco RENAME TO banco_old;'"
$SSH admin@10.0.3.10 "sudo -n -u postgres psql -c 'ALTER DATABASE banco_tmp RENAME TO banco;'"
```

Verificação. Subir a aplicação, acessar o site por HTTPS e conferir que os dados esperados aparecem. **Reversão.** Se algo estiver errado, parar a aplicação e renomear de volta (`banco → banco_tmp` e `banco_old → banco`); se necessário, restaurar o `pre_restauracao.sql`. Após a validação, remover o banco antigo com `dropdb banco_old`.

3.2 Adição de novos usuários

Os três procedimentos abaixo são executados pelo administrador a partir do pc-admin (origem 10.0.2.5), acessando cada servidor por SSH. Nos exemplos, `novousuario`, `novo` e `novoadmin` são nomes ilustrativos.

(a) Usuário do Samba (srv-arquivos)

```
sudo useradd -M -s /usr/sbin/nologin novousuario
sudo smbpasswd -a novousuario
sudo nano /etc/samba/smb.conf        # em [corporativo]: valid users = usuario novousuario
testparm -s /etc/samba/smb.conf
sudo systemctl reload smbd
```

Ajustar a permissão de escrita no diretório conforme a política (por exemplo, por grupo POSIX). **Verificação** (de um host da LAN): `smbclient //10.0.4.10/corporativo -U novousuario -c ls`. **Reversão:** `sudo smbpasswd -x novousuario`, `sudo userdel novousuario`, remoção do nome em `valid users` e novo `reload`.

(b) Role no PostgreSQL (srv-db)

```
P="sudo -u postgres psql -d banco"
$P -c "CREATE ROLE novo LOGIN;"
$P -c "\password novo"
$P -c "GRANT CONNECT ON DATABASE banco TO novo;"
$P -c "GRANT USAGE ON SCHEMA public TO novo;"
$P -c "GRANT SELECT, INSERT, UPDATE, DELETE ON ALL TABLES IN SCHEMA public TO novo;"
echo "host banco novo 10.0.1.10/32 scram-sha-256" | sudo tee -a /etc/postgresql/17/main/pg_hba.conf
$P -c "SELECT pg_reload_conf();"
```

A senha é digitada de forma interativa (`\password`) para não ficar no histórico do shell, e o privilégio é mínimo: sem superusuário e sem criação de objetos. **Verificação** (a partir do srv-web): `psql -h 10.0.3.10 -U novo -d banco -c "SELECT 1;"`. **Reversão:** remover a linha do `pg_hba.conf`, recarregar a configuração e executar `REVOKE ALL ON ALL TABLES IN SCHEMA public FROM novo`, `REVOKE ALL ON SCHEMA public FROM novo`, `REVOKE ALL ON DATABASE banco FROM novo` e `DROP ROLE novo`.

(c) Administrador SSH (zonas DMZ, DB e Files)

```
sudo useradd -m -s /bin/bash novoadmin
sudo install -d -m 700 -o novoadmin -g novoadmin /home/novoadmin/.ssh
sudo install -m 600 -o novoadmin -g novoadmin chave_novoadmin.pub /home/novoadmin/.ssh/authorized_keys
sudo sed -i 's/^AllowUsers .*/& novoadmin/' /etc/ssh/sshd_config.d/10-projeto.conf
sudo sshd -t
for z in dmz db files; do sudo kill -HUP $(cat /run/sshd-$z.pid); done
```

Como os namespaces compartilham usuários e arquivos de configuração, o usuário é criado uma única vez. A R4 libera apenas o endereço 10.0.2.5; o novo administrador deve usá-lo como origem ou a regra precisa ser ajustada. **Verificação:** `ssh -i chave_novoadmin -b 10.0.2.5 novoadmin@10.0.1.10 true`. **Reversão:** remover o nome de `AllowUsers`, validar com `sshd -t`, repetir o `kill -HUP` e executar `sudo userdel -r novoadmin`.

4 Análise de segurança

A arquitetura separa o que é exposto à internet (DMZ), o que é interno (LAN e servidor de arquivos) e o que é confidencial (banco de dados), e aplica a cada fronteira uma política de negação por padrão. O objetivo é que a invasão de um componente exposto não leve, por si só, aos dados do negócio.

4.1 Decisões de arquitetura e justificativas

Tabela 5. Decisão, ameaça mitigada e evidência

Decisão	Ameaça mitigada	Evidência
Segmentação em zonas (DMZ, LAN, DB, Files)	Movimento lateral: a invasão do servidor web não dá acesso direto ao banco nem aos arquivos	Matriz de firewall; testes negativos das regras R2 e R3
Política padrão drop	Portas e serviços não previstos permanecem inacessíveis, inclusive os esquecidos	:8080 e DMZ → Files:445 em filtered; 21 pacotes no descarte final
Defesa em camadas no banco (R2)	A falha de uma camada não expõe o banco: firewall, pg_hba.conf e bind por IP se sobrepõem	R2 + pg_hba 10.0.1.10/32 com scram-sha-256 + listen em 10.0.3.10; R5 com 9 pacotes bloqueados
Aplicação atrás do proxy reverso	Acesso direto ao uvicorn e exploração fora do Nginx	FastAPI em 127.0.0.1:8000; só 80 e 443 liberadas na R1
Menor privilégio	Abuso de credenciais e de contas com poder excessivo	AllowUsers admin; PermitRootLogin no; role da aplicação sem superusuário; valid users no Samba; serviços presos ao IP da zona
SSH somente por chave	Força bruta e vazamento de senhas	PasswordAuthentication no; tentativa sem chave recusada (publickey)
TLS, cabeçalhos de segurança e rate limiting	Interceptação, downgrade de protocolo e abuso de requisições	TLS 1.2 e 1.3, HSTS, X-Content-Type-Options, server_tokens off; 5 req/s por IP, burst 10
Firewall stateful	Pacotes forjados ou fora de conexão válida	ct state invalid descartado; established,related aceito
Log do bloqueio ao banco	Falta de rastreabilidade de tentativas de acesso direto	Prefixo DROP-DB no log do kernel (evidencias/log-drop-db.txt)

4.2 Limitações

- Os namespaces isolam a rede, mas compartilham kernel, sistema de arquivos, usuários e chaves de host SSH. Em produção, cada zona seria uma máquina ou VM distinta.
- O administrador é identificado pelo IP de origem (10.0.2.5), que pode ser forjado por quem estiver na LAN; pc-usuario e pc-admin são dois endereços do mesmo namespace.
- A delegação de sudo ao admin sobre o usuário postgres, necessária ao backup, concentra privilégio e deve ser restrita aos comandos listados e auditada.
- O certificado TLS é autoassinado: o navegador exibe alerta e não há validação por terceiros.
- Não há IDS/IPS nem monitoramento centralizado de logs.
- Não há tráfego de saída das zonas para a WAN: atualizações de pacotes exigiriam uma regra específica.

- Ambiente de laboratório, em um único host físico e sem redundância.

4.3 Melhorias propostas

- Administração por VPN (WireGuard) ou VLAN dedicada, com segundo fator, no lugar da identificação por IP.
- Certificados emitidos por uma CA confiável (Let's Encrypt) ou por uma CA interna.
- IDS/IPS (Suricata) e centralização de logs (rsyslog ou Loki), com alerta para eventos DROP-DB.
- Filtragem de saída (*egress*) com proxy ou repositório interno para atualizações.
- Limitação de tentativas de SSH (fail2ban) e rotação periódica de chaves.
- Zonas em VMs separadas, firewall em máquina própria e regras versionadas e aplicadas por automação (Ansible).
- Cópia dos backups em local externo (regra 3-2-1) e teste periódico de restauração.

Arquivos de apoio no repositório: `configs/` *(configurações),* `scripts/` *(topologia, firewall e testes) e* `evidencias/` *(saídas dos testes, contadores e logs).*